דוח מעבדה 1A – זיהוי אירועי אבטחה

Raw Security Logs → Rule-Based Detection → MITRE ATT&CK → SOC Dashboard

מגישות: ליאן מאור ונוי מלינק

תאריך ביצוע: 25.10.2026

מטרת המעבדה

במעבדה בדקנו איך מערכת SOC בסיסית קוראת קובץ לוגים, מזהה אירועים חשודים לפי חוקים ומציגה את ההתרעות ב-Dashboard. בהמשך שינינו את הלוגים בכוונה כדי לראות איך כל שינוי משפיע על התוצאה, ולבסוף הפעלנו סימולטור שמוסיף אירועים חדשים באופן אוטומטי.

1. הפעלת Docker והמערכת

מה עשינו? הפעלנו את Docker, בדקנו את ההגדרות של Docker Compose והרצנו את רכיבי Detector ו-Dashboard. לאחר מכן בדקנו ששניהם במצב Running ושה-Dashboard נפתח בדפדפן בכתובת localhost:8000.

מה הבנו? ה-Detector קורא את הלוגים ומייצר התרעות, וה-Dashboard מציג לנו את הממצאים. שני הרכיבים עובדים יחד, אבל לכל אחד יש תפקיד אחר.



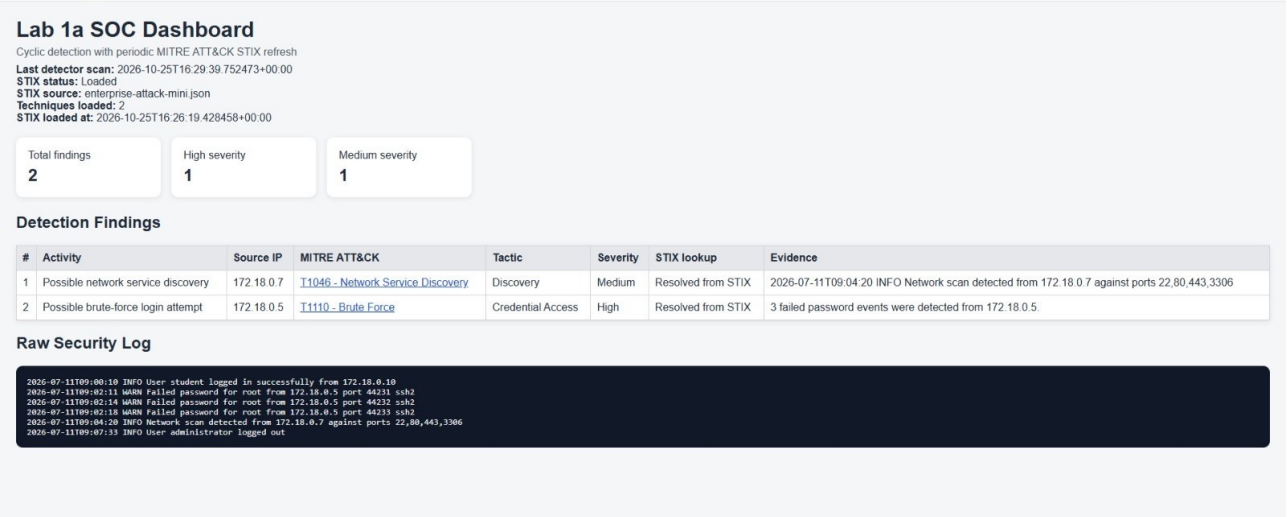
תמונה 1: בדיקת Docker Compose – רכיבי Detector ו-Dashboard במצב Running

2. מצב התחלתי – בדיקת הלוגים

מה עשינו? בדקנו שקובץ security.log מכיל 6 שורות, ופתחנו את ה-Dashboard לפני שביצענו שינויים. המערכת הציגה 2 התרעות: אחת ברמת חומרה גבוהה ואחת ברמת חומרה בינונית.

מה ראינו? T1110 – שלושה ניסיונות התחברות כושלים מהכתובת 172.18.0.5; ו-T1046 – הודעה על סריקת פורטים מהכתובת 172.18.0.7.

מה הבנו? המערכת לא מחליטה לבד אם הייתה תקיפה. היא בודקת אם השורות בלוג מתאימות לחוקים שהוגדרו לה, ומציגה את ההתאמות כחשד שדורש בדיקה.



תמונה 2: מצב התחלתי: 2 התרעות – T1110 ו-T1046

3. טבלת זיהוי האירועים – ראיות, חוק ומיפוי MITRE

בטבלה ריכזנו את שתי ההתרעות מהמצב ההתחלתי ואת הסיבה שבגללה המערכת הציגה אותן.

מה ראינו בלוג?	החוק שהופעל	טכניקת MITRE	Tactic	מה עדיין לא בטוח?
3 שורות Failed password מאותה כתובת: 172.18.0.5	לפחות 3 ניסיונות כושלים מאותו IP	T1110 Brute Force	Credential Access	לא ידוע אם זה תוקף או משתמש שטעה בסיסמה.
שורה מפורשת: Network scan detected מהכתובת 172.18.0.7	זיהוי ההודעה Network scan detected	T1046 Network Service Discovery	Discovery	ייתכן שזו סריקה תקינה לצורכי תחזוקה.

4. איך החוקים עובדים?

לפי הוראות המעבדה והבדיקות שביצענו, החוק T1110 סופר שורות Failed password בנפרד לכל כתובת IP. ברגע שיש לפחות 3 שורות מאותה כתובת, מתקבלת התרעה ברמת High. בחוק הזה אין חלון זמן, ולכן הוא לא בודק אם הניסיונות התרחשו בפרק זמן קצר.

החוק T1046 מחפש שורה שבה מופיע במפורש הביטוי Network scan detected. כלומר, הוא לא מבצע סריקת רשת בעצמו ולא מסיק שקיימת סריקה מתוך תעבורת רשת גולמית.

ב-Dashboard ראינו שהקובץ המקומי enterprise-attack-mini.json נטען בהצלחה (STIX status: Loaded), ושתי טכניקות זמינות למיפוי. המיפוי ל-MITRE עוזר להבין לאיזה סוג פעילות ההתרעה קשורה, אבל הוא לא הוכחה לתקיפה.

5. ניסויים מבוקרים – C1 עד C4

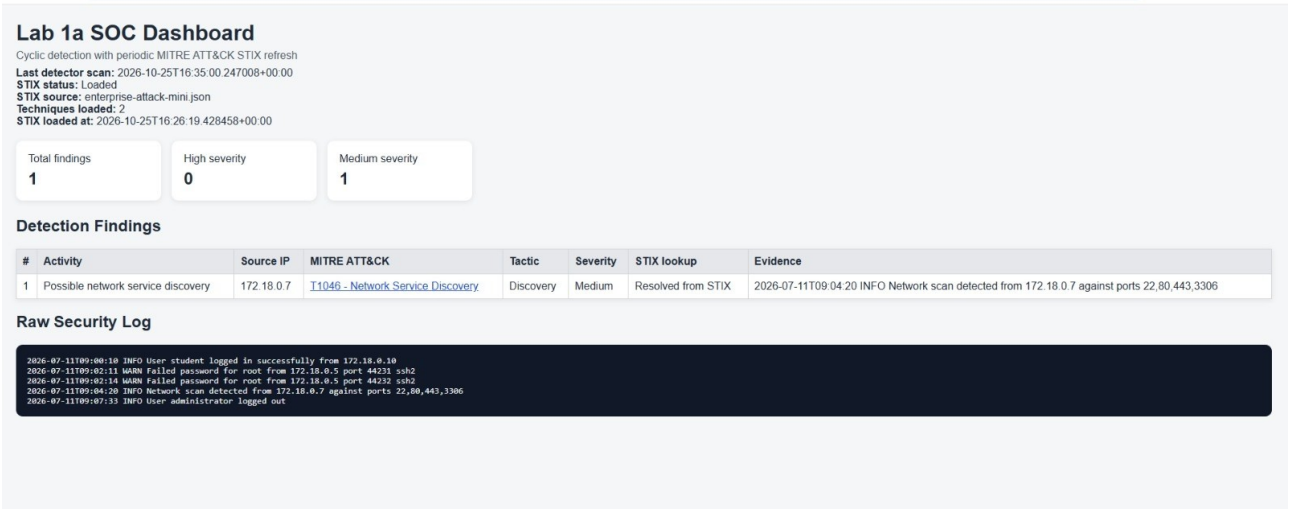
C1 – מחיקת ניסיון התחברות אחד

מה שינינו? מחקנו את השורה של ניסיון ההתחברות השלישי מהכתובת 172.18.0.5 (09:02:18, פורט 44233). נשארו רק שני ניסיונות כושלים מאותה כתובת.

מה ציפינו? שהתרעת T1110 תיעלם ושנישאר עם התרעת T1046 אחת בלבד.

מה קרה בפועל? מספר ההתרעות ירד מ-2 ל-1. לא הייתה התרעת High, והתרעת סריקת הרשת נשארה.

מה הבנו? כשהמספר יורד מתחת לסף של שלושה ניסיונות, החוק של Brute Force כבר לא מופעל.



תמונה 3: ניסוי C1 – נותרה התרעת T1046 אחת

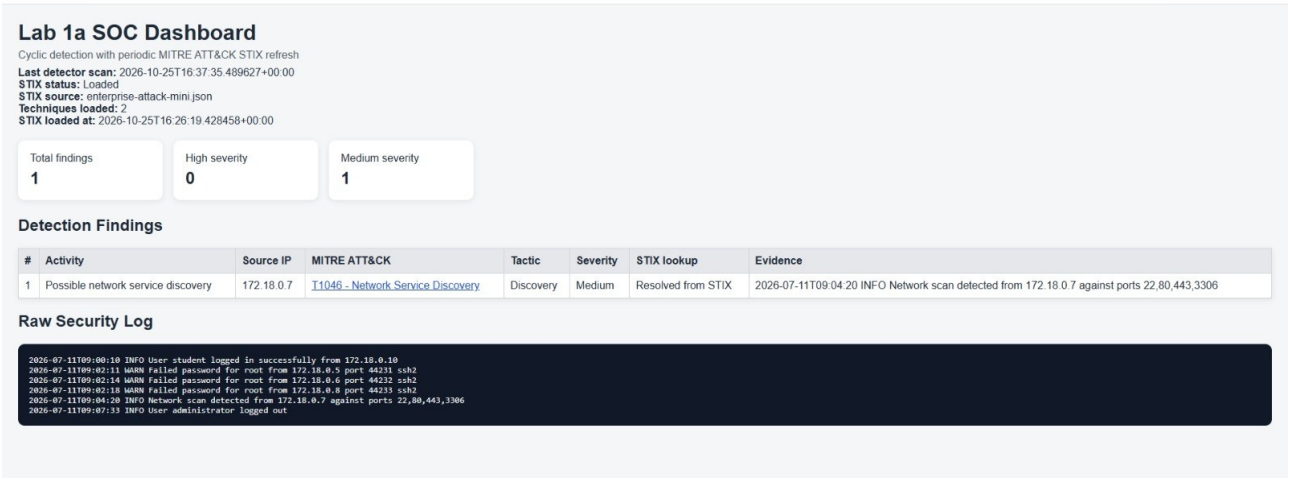
C2 – שלושה ניסיונות משלוש כתובות IP שונות

מה שינינו? החזרנו שלוש שורות Failed password, אבל הגדרנו כתובת שונה לכל שורה: 172.18.0.5, 172.18.0.6 ו-172.18.0.8.

מה ציפינו? שלא תופיע התרעת Brute Force, כי לכל כתובת יש רק ניסיון כושל אחד.

מה קרה בפועל? נשארה התרעה אחת בלבד, של T1046.

מה הבנו? המערכת סופרת את הניסיונות בנפרד לכל כתובת IP. שלושה ניסיונות מכתובות שונות לא עוברים את הסף של אף כתובת.



תמונה 4: ניסוי C2 – שלוש כתובות IP שונות, ללא התרעת Brute Force

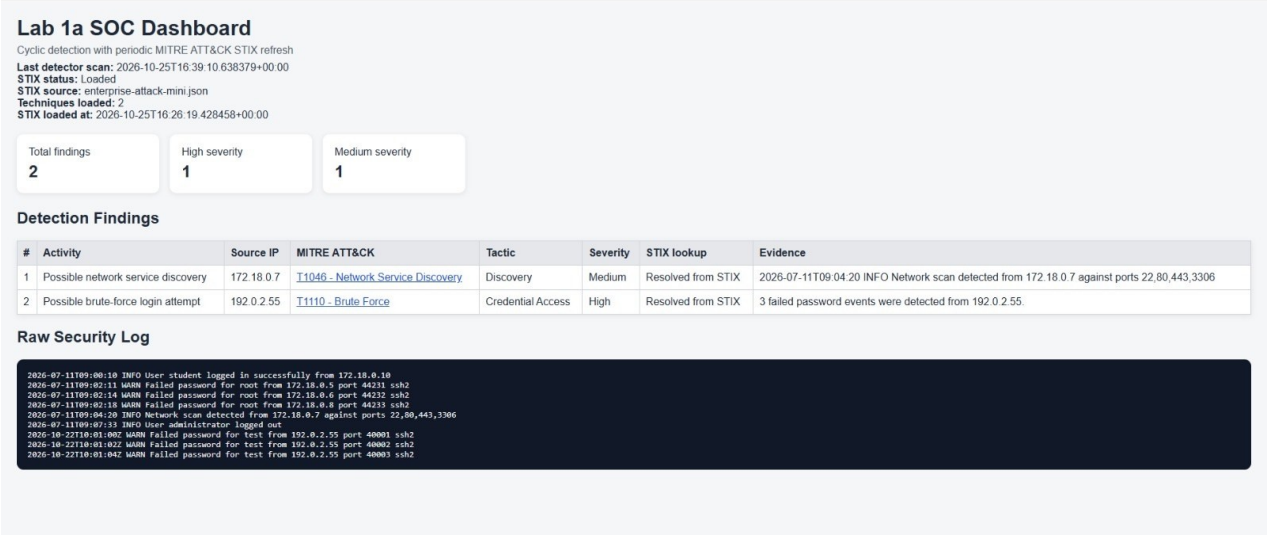
C3 – הוספת שלושה ניסיונות מאותה כתובת חדשה

מה שינינו? הוספנו שלוש שורות Failed password חדשות מהכתובת 192.0.2.55, עם הפורטים 40001, 40002 ו-40003.

מה ציפינו? שתופיע התרעת T1110 חדשה ומספר ההתרעות יעלה מ-1 ל-2.

מה קרה בפועל? מספר ההתרעות עלה ל-2: אחת של T1110 מהכתובת החדשה ואחת של T1046 מהלוג המקורי.

מה הבנו? גם כתובת IP שלא הופיעה קודם יכולה להפעיל את החוק, אם היא מגיעה לשלושה ניסיונות כושלים.



תמונה 5: ניסוי C3 – הופיעה התרעת T1110 חדשה עבור 192.0.2.55

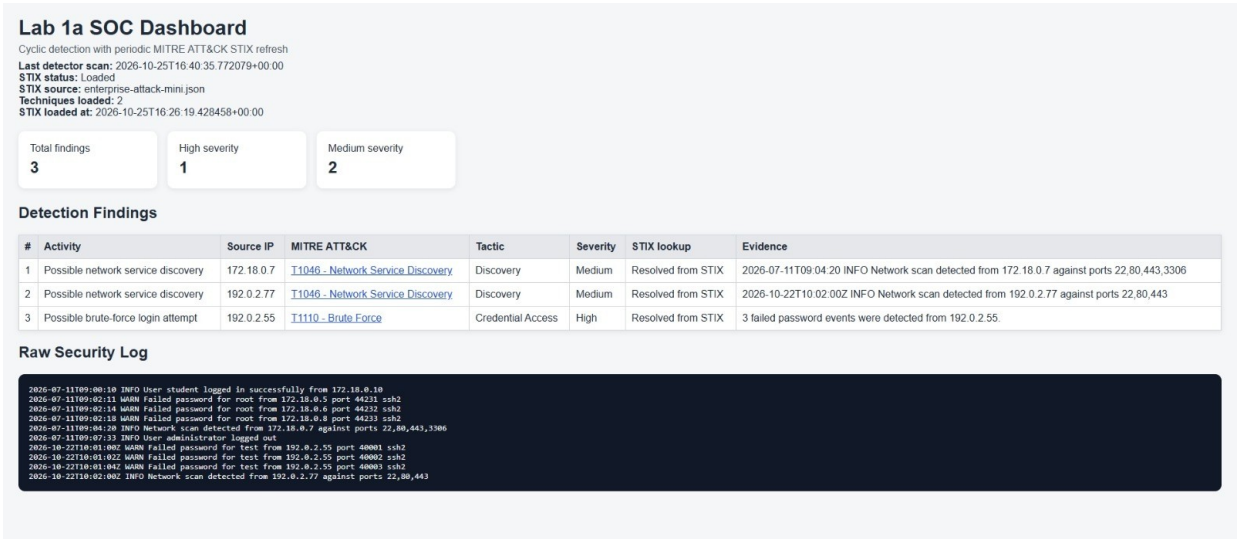
C4 – הוספת הודעה על סריקת רשת

מה שינינו? הוספנו שורת לוג עם ההודעה Network scan detected מהכתובת 192.0.2.77, כנגד הפורטים 22, 80 ו-443.

מה ציפינו? שתופיע התרעת T1046 נוספת ומספר ההתרעות יעלה מ-2 ל-3.

מה קרה בפועל? המערכת הציגה 3 התרעות: אחת High ושתי Medium.

מה הבנו? כל שורת לוג נוספת שמתאימה לחוק של סריקת רשת יכולה להוסיף התרעה נפרדת.



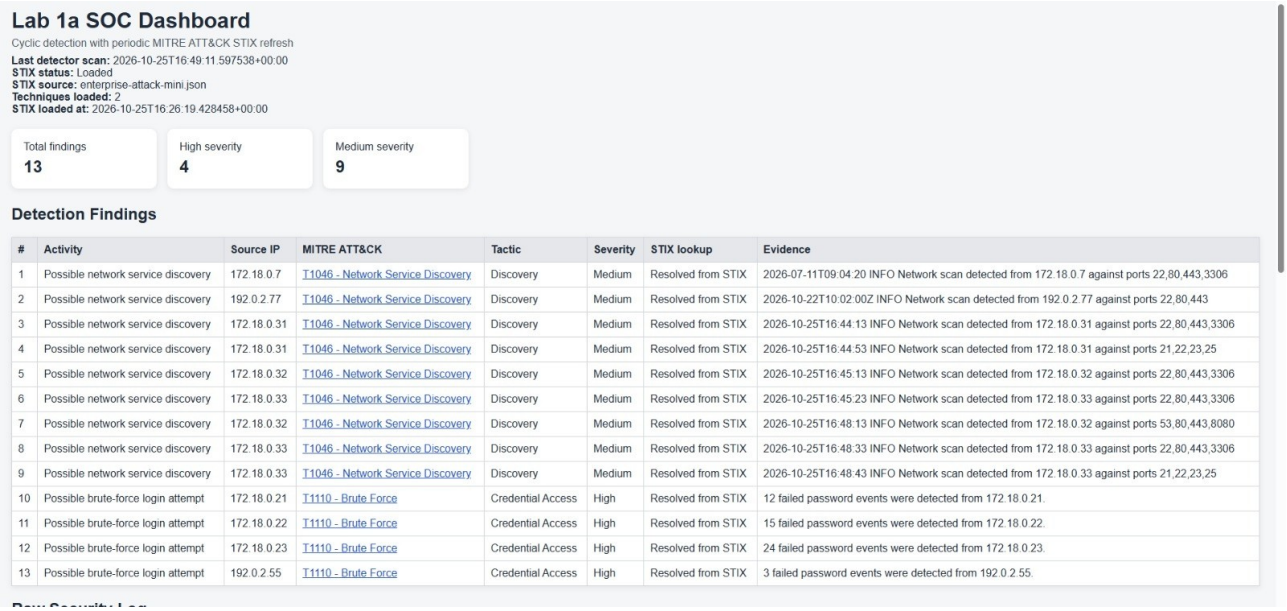
תמונה 6: ניסוי C4 – שלוש התרעות, כולל T1046 חדשה

6. הפעלת הסימולטור

מה עשינו? לאחר שסיימנו את הניסויים הפעלנו את הסימולטור באמצעות Docker Compose. הוא הוסיף באופן אוטומטי אירועים חדשים לקובץ הלוגים, ואנחנו רעננו את ה-Dashboard כדי לראות את השינויים.

מה ראינו? מספר ההתרעות עלה מ-3 ל-13. בצילום המסך רואים 4 התרעות ברמת High ו-9 ברמת Medium. בין הכתובות שהופיעו היו 172.18.0.21, 172.18.0.22 ו-172.18.0.23 בהתרעות T1110, וגם 172.18.0.31, 172.18.0.32 ו-172.18.0.33 בהתרעות T1046.

מה הבנו? המערכת סורקת שוב את הלוגים ומעדכנת את ההתרעות כשהיא מוצאת אירועים חדשים. בניגוד לניסויים הידניים, כאן מספר ההתרעות משתנה עם הזמן ולכן קשה יותר להשוות תוצאה אחת קבועה בין הרצות.



Lab 1a SOC Dashboard

Cyclic detection with periodic MITRE ATT&CK STIX refresh

Last detector scan: 2026-10-25T16:49:11.597538+00:00
STIX status: Loaded
STIX source: enterprise-attack-mini.json
Techniques loaded: 2
STIX loaded at: 2026-10-25T16:26:19.428458+00:00

Total findings	High severity	Medium severity
13	4	9

Detection Findings

#	Activity	Source IP	MITRE ATT&CK	Tactic	Severity	STIX lookup	Evidence
1	Possible network service discovery	172.18.0.7	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-07-11T09:04:20 INFO Network scan detected from 172.18.0.7 against ports 22,80,443,3306
2	Possible network service discovery	192.0.2.77	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-10-22T10:02:00Z INFO Network scan detected from 192.0.2.77 against ports 22,80,443
3	Possible network service discovery	172.18.0.31	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-10-25T16:44:13 INFO Network scan detected from 172.18.0.31 against ports 22,80,443,3306
4	Possible network service discovery	172.18.0.31	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-10-25T16:44:53 INFO Network scan detected from 172.18.0.31 against ports 21,22,23,25
5	Possible network service discovery	172.18.0.32	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-10-25T16:45:13 INFO Network scan detected from 172.18.0.32 against ports 22,80,443,3306
6	Possible network service discovery	172.18.0.33	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-10-25T16:45:23 INFO Network scan detected from 172.18.0.33 against ports 22,80,443,3306
7	Possible network service discovery	172.18.0.32	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-10-25T16:48:13 INFO Network scan detected from 172.18.0.32 against ports 53,80,443,8080
8	Possible network service discovery	172.18.0.33	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-10-25T16:48:33 INFO Network scan detected from 172.18.0.33 against ports 22,80,443,3306
9	Possible network service discovery	172.18.0.33	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-10-25T16:48:43 INFO Network scan detected from 172.18.0.33 against ports 21,22,23,25
10	Possible brute-force login attempt	172.18.0.21	T1110 - Brute Force	Credential Access	High	Resolved from STIX	12 failed password events were detected from 172.18.0.21.
11	Possible brute-force login attempt	172.18.0.22	T1110 - Brute Force	Credential Access	High	Resolved from STIX	15 failed password events were detected from 172.18.0.22.
12	Possible brute-force login attempt	172.18.0.23	T1110 - Brute Force	Credential Access	High	Resolved from STIX	24 failed password events were detected from 172.18.0.23.
13	Possible brute-force login attempt	192.0.2.55	T1110 - Brute Force	Credential Access	High	Resolved from STIX	3 failed password events were detected from 192.0.2.55.

תמונה 7: במהלך הסימולטור: 13 התרעות – 4 ברמת High ו-9 ברמת Medium

בסיום עצרנו את הסימולטור, שחזרנו את קובץ הלוג המקורי מהגיבוי וסגרנו את סביבת Docker.

7. סיכום מנקודת מבט של אנליסט SOC (128 מילים)

בבדיקה הראשונית ראינו שש שורות בקובץ הלוג ושתי התרעות: שלושה ניסיונות התחברות כושלים מאותה כתובת IP, והודעה על סריקת פורטים ברשת. אלו עובדות שמופיעות בלוג וב-Dashboard, אבל הן לא מוכיחות שמישהו באמת ניסה לפרוץ למערכת. בניסוי הראשון מחקנו ניסיון התחברות אחד והתרעת Brute Force נעלמה. בניסוי השני חילקנו את הניסיונות בין שלוש כתובות שונות, וגם אז לא התקבלה התרעה כזאת. בניסוי השלישי הוספנו שלושה ניסיונות מאותה כתובת חדשה וההתרעה הופיעה שוב. בניסוי הרביעי הוספנו הודעה על סריקת רשת והתקבלה התרעת T1046 נוספת. לאחר הפעלת הסימולטור מספר ההתרעות המשיך לעלות, כי נוספו אירועים חדשים. מבחינתנו, המסקנה היא שהמערכת מזהה התאמה לחוקים שהוגדרו לה, ולא בהכרח תקיפה אמיתית. לכן אנליסט SOC צריך לבדוק את ההקשר של האירוע, מי ביצע אותו והאם יש ראיות נוספות לפני שהוא מחליט שמדובר באירוע אבטחה.

8. מסקנה כללית

הדבר העיקרי שלמדנו הוא ששינוי קטן בלוג יכול לשנות את ההתרעות שמופיעות ב-Dashboard. כשמחקנו שורה, התרעה נעלמה; כשפיזרנו ניסיונות בין כתובות שונות, לא הופעלה התרעת Brute Force; וכשהוספנו אירועים מתאימים, הופיעו התרעות חדשות.

בנוסף הבנו את ההבדל בין זיהוי אוטומטי של דפוס חשוד לבין קביעה שבאמת הייתה תקיפה. המערכת עוזרת לאנליסט להתמקד באירועים שכדאי לבדוק, אבל ההחלטה הסופית דורשת בדיקה של ההקשר והראיות.